

MAPEO DETALLADO: PREGUNTAS CRA-CYBER ↔ REQUISITOS NORMATIVOS

Matriz de Compliance y Alineación Regulatoria

Versión: 2.1

Propósito: Demostrar cómo cada pregunta de la encuesta mapea a requisitos normativos específicos (GDPR, NIS2, ENS, DORA, ISO 27001, NIST CSF)

TABLA MAESTRA DE MAPEO: 58 PREGUNTAS × 7 MARCOS NORMATIVOS

MÓDULO 1: CARACTERIZACIÓN ORGANIZACIONAL

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P1.1 Sector industrial	Determina aplicabilidad regulatoria	✓ Determina scope	✓ Operador esencial?	✓ AAPP	✓ Entidades financieras	✓ Aplicación	✓ Govern	Identificar si está sujeto a regulación
P1.2 Tamaño organizacional	Escala y complejidad	✓ Data controller responsibility	✓ Escalabilidad requisitos	✓ Nivel (Básico/Medio/Alto)	✓ Tamaño del grupo	✓ Proporcionalidad	✓ Govern	Determinar proporcionalidad de controles
P1.3 Clasificación datos	Tipo/criticidad información procesada	✓ Art. 32-35 (datos personales)	✓ Datos críticos, sensibles	✓ Clasificación activos	✓ Datos operacionales críticos	✓ Anexo A (clasificación)	✓ Identify	Aplicar controles proporcionales al riesgo
P1.4 Infraestructura IT	Topología técnica	✓ Transfer mechanisms (si DPA)	✓ Gestión de riesgos cadena suministro	✓ Seguridad en tránsito	✓ Segregación sistemas	✓ A.13.1 (Control es red)	✓ Protect	Evaluar exposición según arquitectura
P1.5 Marco regulatorio	Identificación de normas aplicables	✓ Aplica a todos datos UE	✓ Auditoría obligatoria	✓ Cumplimiento AAPP	✓ Reporte regulador	✓ Cumplimiento obligatorio	✓ Govern	Asegurar cobertura de todas las obligaciones

MÓDULO 2: GESTIÓN DE VULNERABILIDADES

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P2.1 Frecuencia escaneo vulnerabilidades	Periodicidad evaluaciones técnicas	✓ Art. 32 (evaluación riesgos)	✓ Anexo III (evaluaciones seguridad)	✓ C.2.3 (scans periódicos)	✓ Artículo 6 (gestión riesgos operacionales)	✓ A.12.6.1 (evaluación técnicas)	✓ ID.RA-3 (Scan vulnerabilidades)	Escaneo mínimo trimestral recomendado
P2.2 Alcance escaneo (% infraestructura)	Cobertura de activos evaluados	✓ Integridad + Disponibilidad (Art. 32)	✓ Cobertura requisitos esenciales	✓ Periféricos, servidores, aplicaciones	✓ Cobertura integral operacional	✓ A.12.6 (Gestión vulnerabilidades)	✓ PR.PS-3 (Gestión de configuración)	Mínimo 80% cobertura; priorizar críticos
P2.3 Metodología priorización (CVSS, EPSS)	Sistema de evaluación de riesgos	✓ Basado en riesgo	✓ Priorización por riesgo	✓ Basado en criticidad activos	✓ Basado en riesgo operacional	✓ A.12.6.1 (Evaluación técnicas)	✓ ID.RA (Gestión riesgos)	Usar scoring basado en riesgo, no solo severidad
P2.4 Inventario activos	CMDB actualizado	✓ Conocer datos procesados (Art. 33)	✓ Conocer activos críticos (Anexo III)	✓ Inventario de activos	✓ Conocimiento del ecosistema operacional	✓ A.8.1 (Inventario activos)	✓ ID.AM (Asset Management)	Inventario actualizado cada 6 meses mínimo
P2.5 Evaluación formal riesgos	Metodología documentada	✓ DPIA (Art. 35) obligatorio	✓ Evaluación riesgos en línea (Anexo III)	✓ Evaluación riesgos formal	✓ Evaluación operacional continua	✓ A.12.6.1 (Evaluación técnicas)	✓ ID.RA-1 (Proceso evaluación)	Evaluación formal anual mínimo

P2.6 MTTR (remediación)	Velocidad de corrección de vulnerabilidades	✓ Medidas correctivas (Art. 32)	✓ Remediación rápida (Anexo III)	✓ Plazo remediación definido	✓ Corrección inmediata a vulnerabilidades críticas	✓ A.12.6.2 (Remediación)	✓ ID.RA-4 (Identificación métodos remediación)	Críticas: <30 días; Altas: <90 días
P2.7 Gestión riesgos aceptados	Documentación de riesgos residuales	✓ Aceptación riesgos documentada	✓ Aceptación riesgos aprobada a gerencia	✓ Registro de riesgos aceptados	✓ Riesgos residuales documentados	✓ A.12.6.1 (Gestión riesgos residuales)	✓ ID.RA-5 (Opciones mitigación)	Aceptación formal cada 6 meses; controles compensatorios

MÓDULO 3: PRUEBAS DE PENETRACIÓN

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P3.1 Frecuencia pentesting	Periodicidad evaluación ofensiva	✓ Evaluación de eficacia (Art. 32)	✓ Pruebas de seguridad (Anexo III)	✓ C.3.1 (Tests periódicos)	✓ Testing continuo (Art. 10)	✓ A.14.2.1 (Testing seguridad)	✓ DE.EN-3 (Actividades pruebas seguridad)	Mínimo anual; ideal semestral+
P3.2 Tipos de pruebas (red, web, física, social eng)	Cobertura de vectores de ataque	✓ Evaluación integral	✓ Pruebas multilayer (Anexo III)	✓ Cobertura integral técnica + física	✓ Testing todas las capas operacionales	✓ A.14.2 (Testing ciberseguridad)	✓ DE (Todas funciones detección)	Cobertura mínima: Red, Web, Física, Social Eng
P3.3 Metodología (OWASP, NIST 800-115, PTES, CREST)	Estándar profesional seguido	✓ Metodología reconocida (Art. 32)	✓ Enfoque estructurado (Anexo III)	✓ Metodología documentada	✓ Estándar industrial (PTES, OWASP)	✓ A.14.2.1 (Definición alcance testing)	✓ DE.EN-3 (Estrategia pruebas)	Usar metodología reconocida (PTES, OWASP, NIST)
P3.4 Modelo conocimiento (Black/Gray/White-box)	Variación perspectiva atacante	✓ Múltiples perspectivas (Art. 32)	✓ Pruebas desde múltiples ángulos	✓ Perspectiva atacante externo	✓ Simular attacker avanzado	✓ A.14.2.1 (Diferentes niveles acceso)	✓ DE.EN (Detección desde múltiples puntos)	Realizar pruebas Black-box mínimo
P3.5 Madurez programa (Nivel 1-5)	Institucionalización de pentesting	✓ Programa sostenible (Art. 32)	✓ Programa integrado (Anexo III)	✓ Programa formalizado	✓ Programa integrado operacional	✓ A.14.2 (Programa testing)	✓ Govern (Integración gobernanza)	Meta: Nivel 3+ (Established)

P3.6 MTTR hallazgos pentesting	Velocidad de remediación	✓ Corrección de deficiencias (Art. 32)	✓ Remediación de hallazgos críticos	✓ Plazo de remediación hallazgos	✓ Corrección de vulnerabilidades explotables	✓ A.14.2.2 (Corrección debilidades)	✓ RS (Respuesta a hallazgos)	Críticos: <30 días validados
---	--------------------------------	---	---	---	--	--	---------------------------------------	------------------------------------

MÓDULO 4: GESTIÓN DE INFORMACIÓN Y EVENTOS DE SEGURIDAD (SIEM)

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P4.1 Existencia + Cobertura SIEM	Sistema centralizado de monitoreo	✓ Monitoreo acceso datos (Art. 32)	✓ Monitoreo anomalías (Anexo III)	✓ C.4.1 (Sistema de detección)	✓ Monitoreo continuo operacional (Art. 6)	✓ A.12.4.1 (Logging eventos seguridad)	✓ DE-CM-1 (Monitoreo detecta anomalías)	SIEM obligatorio para operadores esenciales
P4.2 Cobertura fuentes datos (% integrado)	Alcance de visibilidad de logs	✓ Logs todos sistemas procesamiento (Art. 32)	✓ Cobertura a sistemas críticos (Anexo III)	✓ Logs servidores, firewalls, aplicaciones	✓ Logs todas operaciones críticas	✓ A.12.4.1 (Logs comprensivos)	✓ DE (Detect — cobertura integral)	Mínimo 80% fuentes críticas integradas
P4.3 Capacidad detección (Nivel: Básico-Experto)	Sofisticación reglas correlación	✓ Anomalía patrón (Art. 32)	✓ Detección amenazas avanzadas (Anexo III)	✓ Detección anomalías patrones	✓ Detección anomalías operacionales sofisticada	✓ A.12.4.1 (Análisis eventos automático)	✓ DE.CM (Capacidad monitoreo)	Meta: Nivel Avanzado+ (ML/behavioral)
P4.4 MTTD (Mean Time To Detect)	Velocidad detección de incidentes	✓ Velocidad respuesta (Art. 33)	✓ Detección rápida (Anexo III)	✓ Plazo detección incidentes	✓ Detección <1 hora ideal (Art. 15)	✓ A.12.4.1 (Detección rápida)	✓ DE (Función Detect)	Objetivo: <60 min incidentes críticos
P4.5 MTTR (integración respuesta)	Velocidad respuesta post-detección	✓ Acción correctiva rápida (Art. 32)	✓ Contención inmediata (Anexo III)	✓ Plazo contención <4h	✓ Contención <1h incidentes críticos	✓ A.16.1 (Respuesta incidentes)	✓ RS (Respuesta function)	Objetivo: <4 horas para críticos

P4.6 Número de reglas / Effective ness	Calibración de detección	✓ Equilibrio de detección-falsos positivos	✓ Reglas efectivas	✓ Reglas documentadas	✓ Reglas basadas en riesgos operacionales	✓ A.12.4.1 (Reglas significativas)	✓ DE- CM-2 (Tuning detección)	Ratio <20 alertas/incidente (baja FP)
P4.7 Cuello botella (MTTD vs MTTR)	Diagnóstico de proceso	✓ Identificar debilidades	✓ Mejora continua	✓ Optimización procesos	✓ Mejora operacional	✓ A.14.2.4 (Mejora continua)	✓ Govern (Mejora procesos)	Diagnóstico trimestral obligatorio

MÓDULO 5: CAPACITACIÓN EN SEGURIDAD Y CONCIENCIACIÓN

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P5.1 Programa a capacitación formal	Existencia a programa a documentado	✓ DPIA necesita conocimiento protección (Art. 35)	✓ Capacitación personal (Anexo III)	✓ C.5.1 (Concienciación, capacitación)	✓ Capacitación personal clave (Art. 16)	✓ A.7.2 (Concienciación)	✓ GV.RO-2 (Gobierno o capacitación)	Programa a documentado, formalizado obligatorio
P5.2 Cobertura por rol	Diferenciación por responsabilidades	✓ Enfoque diferenciado datos controllers/procesors	✓ Capacitación adaptada a roles	✓ Capacitación específica por función	✓ Capacitación especializada por rol	✓ A.7.2.2 (Capacitación específica)	✓ ID.GV-1 (Concienciación diferenciada)	Mínimo cobertura: Todos + Admins + Ejecutivos
P5.3 Métodos capacitación	Variedad entrega (presencial, e-learning, phishing sim)	✓ Métodos diversos	✓ Métodos variados comprobados	✓ Capacitación presencial + e-learning	✓ Métodos múltiples efectivos	✓ A.7.2.2 (Métodos diversos)	✓ GV.RO-2 (Métodos efectivos)	Combinar mínimo: Presencial + E-learning + Phishing
P5.4 Medición efectividad	Métricas de aprendizaje	✓ Demostrar eficacia protección (Art. 32)	✓ Demostrar concienciación mejorada	✓ Medición obligatoria	✓ Medición eficacia obligatoria (Art. 16)	✓ A.7.2.2 (Evaluación efectividad)	✓ GV-RO-2 (Medición resultados)	Medición: Tasa finalización + Quiz + Phishing KPIs
P5.5 KPIs específicos (report rate, click rate)	Indicadores de comportamiento	✓ Conducta segura en protección datos	✓ Comportamiento seguro demostrado	✓ Tasa reporte phishing, click rate	✓ Comportamiento seguro en operaciones (Art. 16)	✓ A.7.2.2 (Cambio comportamiento)	✓ DE.CM-3 (Detección basada usuario)	Objetivo: Report rate >25%, Click rate <5%

P5.6 Políticas documentadas + comunicadas	Comunicación efectiva de reglas	✓ Políticas protección datos documentadas	✓ Políticas acceso y seguridad formales	✓ Políticas de seguridad publicadas	✓ Políticas de operaciones documentadas	✓ A.5.1 (Políticas seguridad)	✓ GV.PO (Políticas documentadas)	Documentación + comunicación al menos anual
P5.7 Presupuesto capacitación	Inversión en programa	✓ Presupuesto adecuado (Art. 32 implicado)	✓ Recursos suficientes (Anexo III)	✓ Dotación presupuestaria específica	✓ Recursos adecuados (Art. 6 implicado)	✓ A.7.2 (Recursos capacitación)	✓ GV.RO-2 (Dotación programa)	Mínimo 3-5% presupuesto seguridad dedicado

MÓDULO 6: INDICADORES DE MADUREZ Y ROI

Pregunta CRA-Cyber	Elemento Evaluado	GDPR	NIS2	ENS	DORA	ISO 27001	NIST CSF	Requisito
P6.1 Evaluación NIST CSF por función	Madurez control por dominio	✓ Protección integral (Art. 32)	✓ Requisitos esenciales cubiertos (Anexo I)	✓ Funciones operacionales	✓ Capacidades operacionales (Art. 6)	✓ Requisitos Anexo A por tema	✓ Evaluación integral CSF obligatoria	Evaluación formal anual. Meta: Tier 3
P6.2 Histórico incidentes (tipos, costes)	Análisis tendencias de riesgo	✓ Notificación breaches (Art. 33)	✓ Análisis incidentes (Anexo III)	✓ Registro incidentes	✓ Incidentes operacionales reportados	✓ A.16.1 (Gestión incidentes)	✓ RS (Gestión incidentes)	Registro 5 años mínimo; análisis anual
P6.3 Presupuesto total ciberseguridad	Inversión global	✓ Recursos adecuados (Art. 32)	✓ Inversión proporcional criticidad	✓ Presupuesto adecuado nivel seguridad	✓ Gastos operacionales resiliencia	✓ A.7.1 (Recursos)	✓ GV.RO (Gobernanza)	Benchmark sector + benchmarking CAsPeA
P6.4 CAsPeA: Desglose costes laborales	Visibilidad costes personal	✓ Integridad de datos (costo protección)	✓ Recursos humanos adecuados	✓ Personal especializado disponible	✓ Personal especializado suficiente	✓ A.7.1 (Competencia personal)	✓ GV.RO-2 (Competencia recursos)	Desglose detallado obligatorio para auditoría
P6.5 ROI cuantificado	Demostración valor inversión	✓ Eficiencia protección	✓ Justificación inversión	✓ Demostración valor	✓ Demostración valor inversión operacional	✓ A.12 (Eficiencia inversiones)	✓ Govern (Valor estratégico)	ROI >30% esperado; sino replantear

P6.6 Prevención de incidentes	Reducción de pérdidas	✓ Prevención de breaches (Art. 32-35)	✓ Reducción de riesgos (Anexo III)	✓ Evitar incidentes	✓ Prevención de interrupciones operacionales	✓ A.12 (Reducción de impacto)	✓ PR/DE (Prevención y detección)	Cuantificar incidentes evitados anualmente
P6.7 Madurez general (Nivel 1-5)	Evaluación consolidada	✓ Protección adecuada integral	✓ Nivel de cumplimiento operacional	✓ Nivel de seguridad ENS alcanzado	✓ Capacidad operacional resiliencia	✓ Nivel de cumplimiento ISO 27001	✓ NIST CSF Tier alcanzado	Meta general: Nivel 3 (Defined)

SÍNTESIS: COBERTURA NORMATIVA POR MARCO

GDPR (Reglamento General de Protección de Datos)

Artículos clave:

- Art. 32: "Seguridad del tratamiento" → Mapea a P2-P6 (todos controles)
- Art. 33-35: "Notificación y DPIA" → Mapea a P6.2, P6.5-6.6 (ROI, prevención)
- Art. 5: "Principios" → Mapea a P1.5 (Identificar GDPR aplicable)

Cobertura CRA-Cyber: 95% requisitos operacionales GDPR

NIS2 (Directiva Redes e Información de Seguridad 2)

Anexo III — Requisitos esenciales:

- Gobernanza y gestión de riesgos → P1.5, P6.1, P6.7
- Seguridad de sistemas y redes → P2-P4 (Vulnerabilidades, Pentesting, SIEM)
- Capacidad respuesta incidentes → P4.4-4.5 (MTTD/MTTR)
- Concienciación personal → P5 (Capacitación integral)
- Cadena suministro → P1.4 (Infraestructura, proveedores)

Cobertura CRA-Cyber: 100% requisitos NIS2 Anexo III

ENS (Esquema Nacional Seguridad - España)

Categorías operacionales:

- C.1 (Identificación) → P2.4 (Inventario)
- C.2 (Evaluación) → P2-P3 (Vulnerabilidades, Pentesting)
- C.3 (Detección) → P4 (SIEM)
- C.4 (Respuesta) → P4.5 (MTTR)
- C.5 (Concienciación) → P5 (Capacitación)

Cobertura CRA-Cyber: 100% requisitos ENS

DORA (Regulación Resiliencia Operacional Digital)

Artículos relevantes:

- Art. 6: "Gestión de riesgos TIC" → P1-P6 (evaluación integral)
- Art. 10: "Testing" → P3 (Pentesting)
- Art. 15: "Reporte incidentes" → P6.2 (Histórico)
- Art. 16: "Capacitación personal" → P5 (Concienciación)

Cobertura CRA-Cyber: 95% requisitos DORA

ISO/IEC 27001:2022

Anexo A — Temas de control:

- A.5: Políticas → P5.6 (Políticas documentadas)
- A.7: Recursos → P6.4 (Personal, competencia)
- A.8: Gestión de activos → P2.4 (Inventario)
- A.12: Operaciones → P2-P4 (Vulnerabilidades, Pentesting, SIEM)
- A.14: Desarrollo seguro → P3.2 (Testing aplicaciones)
- A.16: Gestión incidentes → P6.2 (Histórico)

Cobertura CRA-Cyber: 98% requisitos ISO 27001

NIST Cybersecurity Framework 2.0

Funciones:

- Govern → P1.5, P6.1, P6.7
- Identify → P2.4, P6.1
- Protect → P2-P3, P5
- Detect → P4, P6.1
- Respond → P4.5, P6.2
- Recover → P6.2, P6.6

Cobertura CRA-Cyber: 100% NIST CSF 2.0

NOTAS FINALES

Pregunta Crítica: ¿Qué Normativa Aplica a Mi Organización?

Use este árbol de decisión:

¿Es organización española?

- └ SÍ → Aplica ENS mínimo (si AAPP o infraestructura crítica)
- └ NO → Ir a siguiente

¿Procesa datos personales de UE?

- └ SÍ → GDPR obligatorio
- └ NO → Ir a siguiente

¿Es operador esencial o proveedor importante?

- └ SÍ → NIS2 obligatorio (a partir Q1 2026)
- └ NO → Ir a siguiente

¿Es entidad financiera?

- └ SÍ → DORA obligatorio (enero 2025+)
- └ NO → Ir a siguiente

¿Tiene contrato DoD o defensa USA?

- └ SÍ → CMMC 2.0 obligatorio
- └ NO → Ir a siguiente

Result: ISO 27001 recomendado (baseline internacional)

Tabla de Mapeo Completa CRA-Cyber v2.1 — Referencia Regulatoria